Ready for machine-speed attackers?

Trinidad and Tobago's banks and financial institutions in the age of AI-enabled hacking

Economic research | Shane Dante Bideshi | 28 October 2026

Executive assessment

Between 2024 and 2026, hacking changed. At first, attackers used AI as an assistant. Now AI agents can carry out most of an intrusion while a human supervises. In 2025, a group assessed as Chinese state-sponsored used an AI coding agent to perform an estimated 80-90% of an espionage campaign against about 30 organisations, financial institutions among them. In September 2026, a security vendor reported that one operator, relying mainly on inexpensive Chinese open-weight models with a US model coordinating them, compromised at least 27 online retailers to varying degrees in five days, at an average cost of about US$25 per target scanned. In October 2026, South Korea's financial regulator said attacks suspected of being driven by AI agents had hit 16 financial firms.

Chinese and other open-weight models do not matter because they are the strongest hacking tools. They are not. Most AI-assisted intrusions documented so far used closed US models, whose developers detected and stopped them, usually after the fact. Government evaluators place the best open-weight models roughly four to eight months behind leading US models on cyber tasks. They matter because anyone can download them, strip out their safety controls cheaply and run them where no AI company can monitor or stop them. US and UK evaluators found that one such model, once given initial network access, can autonomously attack "small, weakly defended and vulnerable enterprise systems". **Parts of a small country's financial system may fit that description**, particularly smaller credit unions, brokers and vendors with few security staff, although no public data measure how exposed Trinidad and Tobago's internet-facing systems are.

Trinidad and Tobago has already been hit repeatedly by conventional attackers:

- ransomware at TSTT, the National Insurance Board, Massy Stores and Venture Credit Union, and a network intrusion at the Attorney General's ministry;
- a chief-executive impersonation fraud in which CIBC Caribbean's Trinidad operation transferred about $14.8 million (currency not stated), about $9.4 million of it unrecovered when reported;
- deepfake videos of the Prime Minister and the Minister of Finance used to sell fraudulent investments.

No public evidence shows an AI-driven intrusion into a local bank, or a confirmed compromise of a commercial bank's core systems. That silence is not proof of strength, and it is not proof of weakness either.

Judgment: on public evidence, Trinidad and Tobago's financial sector is not ready to defend against a determined hacker group armed with current AI tools. The weakness lies mainly in the system around the institutions, not in anything observed inside them. Bank-level defences cannot be judged from public sources, and few financial systems anywhere could claim to be fully ready for such a group. The largest banks are partly ready for routine attacks. Strong capital, a Central Bank incident-reporting rule in place since 2023 and, for the foreign-owned banks, parent-group security programmes all help. The system around them is not ready:

- The main cybercrime law dates from 2000.
- The Data Protection Act 2011 has been only partly in force since January 2012, and its obligations on organisations have never been proclaimed.
- There is no published supervisory response to frontier AI.
- Incident counts cover only what is voluntarily reported, few private firms report, and no loss figures are published.
- The credit-union sector has no prudential or cyber supervisor.
- Several banks still offer or rely on SMS codes, which travel over a two-company mobile market with no published SIM-swap controls.

On this report's scorecard, which mainly measures the framework around institutions rather than tested defences, overall readiness is **about 2 out of 5**.

Question	Finding
Has AI changed hacking?	Yes. Between 2024 and 2026 it moved from drafting phishing emails to running most steps of real intrusions. It mainly makes existing techniques faster and cheaper; it has not invented new types of attack.
Do Chinese and open-weight models matter?	Yes, but not because they are the best. Most documented AI-assisted intrusions used closed US models. Open-weight models are good enough against weakly defended targets, cheap, and beyond the reach of any company's safety monitoring.
Has an AI-enabled attack hit a T&T bank?	Not on public evidence. Locally, AI has so far appeared in deepfake investment scams. Losses have come from ransomware, impersonation and account takeover.
Are the largest banks prepared?	Partly, against common attacks. SMS codes remain selectable at several banks, and none of the banks reviewed publicly describes confirmation-of-payee checks; two large banks could not be reviewed. Public evidence cannot show how well their internal defences work.
Is the wider system prepared?	No. The main gaps are law, the speed of supervision, information sharing, incident and loss data, shared infrastructure, and the credit-union and securities periphery.
What would most improve readiness quickly?	A Central Bank frontier-AI directive, a sector payment-verification standard, a rapid fraud-freeze protocol and published incident data. Each can be done within months without new legislation.

Scope and evidence: research completed 28 October 2026 using public sources only: regulator and government documents, parliamentary records, company reports, AI-developer and security-vendor threat reports, and news coverage. No institution's systems were tested and no confidential supervisory information was available. Ratings are analytical judgments. A public-evidence review can understate controls that institutions do not disclose and overstate controls that exist only on paper. Sources and methods appear at the end.

Terms used in this report

Term	Meaning
Phishing, smishing, vishing	Deceptive emails, text messages and phone calls designed to steal passwords, codes or payments.
Business email compromise (BEC)	Impersonating an executive, supplier or client to get an employee to send money or data.
Ransomware	Malware that locks an organisation's systems and usually steals data, followed by an extortion demand.
Deepfake	AI-generated video, voice or images that imitate a real person.
Open-weight model	An AI model whose underlying files are published. Anyone can download and run it on their own computers, outside the developer's control.
Abliteration	Removing a model's refusal behaviour so it will assist with harmful tasks.
Zero-day / known (n-day) vulnerability	A flaw unknown to the vendor and unpatched / a flaw that is public and patchable but often left unpatched.
Edge device	Internet-facing equipment such as VPN gateways and firewalls. In 2025-26 these were a leading entry point for attackers.
MFA, OTP	Multi-factor authentication; a one-time passcode, often sent by SMS.
SIM swap	Moving a victim's phone number to an attacker's SIM card to intercept SMS codes.
Confirmation of payee	A check that warns the sender when the account name does not match the intended recipient.
Frontier model	One of the most capable AI models available at a given time.
Cyber range	A simulated computer network used to test how far an attacker, or an AI model, can get.
Prudential supervision	Supervision of an institution's soundness: its capital, liquidity and risk management.
CSIRT, ISAC	A national or sector incident-response team; an information-sharing centre where institutions exchange threat warnings.
Threat-led penetration testing	Authorised simulated attacks that copy real attackers' methods.

1. What changed: from AI-assisted to AI-operated attacks

A short history of 2024-2026

In February 2024, Microsoft and OpenAI reported that state-linked groups from Russia, China, Iran and North Korea were using AI chatbots. They used them for research, scripting, translation and phishing text. Microsoft said the companies' joint research "has not identified significant attacks employing the LLMs we monitor closely". [1] Two and a half years later, the evidence describes something different.

Date	Event	What AI contributed
Early 2024	An Arup employee in Hong Kong sent HK$200 million (about US$25.6m) after a video call in which the chief financial officer and colleagues were deepfakes [18]	Fake faces and voices; no computer system was hacked
Jul 2025	Malware attributed to Russia's APT28 (LAMEHUG) called Alibaba's open-weight Qwen model to write its commands while running [7, 10]	First malware Google had seen querying an AI model in live operations
Aug 2025	One criminal used Claude Code against at least 17 organisations [2]	Reconnaissance, intrusion, choosing what to steal, and setting ransom demands from victims' own financial data

Date	Event	What AI contributed
Aug-Sep 2025	The open-source HexStrike-AI framework was discussed on criminal forums for exploiting newly disclosed Citrix NetScaler flaws within hours [11]	Automating exploitation of freshly published flaws (attacker claims)
Sep 2025 (disclosed Nov 2025)	A group assessed as Chinese state-sponsored (GTG-1002) used Claude Code against about 30 targets, including financial institutions; a small number were breached [3]	An estimated 80-90% of tactical work, with 4-6 human decisions per campaign
Feb 2026	Fideuram, Intesa Sanpaolo's private bank, lost about EUR95m after a WhatsApp message impersonating the group chief executive and a call using an AI-cloned voice [19]	Voice cloning to authorise payments; about EUR36m remains untraced
Apr 2026	The US Treasury Secretary and Federal Reserve Chair convened bank chief executives over Anthropic's Mythos Preview, a model able to find and exploit unknown flaws [23]	Supervisory alarm about capability, not a documented attack
May 2026	Google reported the first zero-day it assesses was developed with AI: a two-factor-authentication bypass prepared for mass exploitation [8]	Discovering and weaponising a new flaw
May 2026 (reported Jul 2026)	A Chinese-speaking actor used DeepSeek as an autonomous agent alongside manual hacking against more than 460 targets. The confirmed data theft, from three NetScaler systems, was done by hand; Unit 42 found the autonomous runs fully compromised no target [12]	Autonomous scanning and enumeration; the exploitation that succeeded was manual
Dec 2025-Aug 2026	Anthropic reported suspected affiliates of the ShinyHunters extortion group using Claude in intrusions whose stolen data included payment-card records and bank account identifiers; one software-supplier breach reached about 200 downstream organisations [5]	Reconnaissance, credential theft, exploitation and extortion
Sep 2026	An operator using GLM-5.2 and DeepSeek V4 models, with Claude orchestrating, compromised at least 27 companies, mostly online retailers, to varying degrees in five days, according to an interim vendor report [13]	About US$25 per target scanned; payment-card skimmers found on victims' websites
Sep-Oct 2026	South Korea: suspected AI-agent-driven attacks hit 16 financial firms, exposing about 100,000 personal records [14-16]	Entry through side portals; a regulator review found 130 of 555 firms deficient
Oct 2026	Straiker reported that a Latin American crime group operating through a Mexican front company had used a multi-model framework (CARLIY0S) to target more than 400 Latin American financial institutions [17]	Reconnaissance and credential harvesting, mainly using closed US models

Sources as cited. Counts of "targets" include failed attempts and are not counts of breaches.

What AI does at each stage of an attack

Stage	Documented contribution	Evidence
Reconnaissance	Mapping exposed systems and profiling staff at machine speed	GTG-1002 and the DeepSeek agent campaign [3, 12]
Deception	Fluent, personalised lures in any language; cloned voices and faces	In a 101-person study, fully AI-written spear-phishing achieved a 54% click rate, equal to human experts, against 12% for a control group [21]; Fideuram [19]

Stage	Documented contribution	Evidence
Exploiting known flaws	Shortening the time from public disclosure to attack	Vulnerability exploitation became the leading initial entry route in 2025 breaches (31%), and Verizon says AI is shortening the time from disclosure to exploitation [22]; unverified attacker claims about HexStrike-AI [11]
Finding new flaws	Discovering and weaponising zero-days	The first zero-day Google assesses was developed with AI, disrupted before mass use (May 2026) [8]; Mythos Preview [23, 33]
Malware and movement inside networks	Writing and adapting malicious code	560 of 832 accounts Anthropic banned for cyber misuse used AI to prepare attacks, for example by writing malware [4]
Extortion	Reading stolen financial records to price ransom demands	[2]

What has not changed

The largest losses still come from deceiving people and abusing trusted suppliers:

- North Korea's record US$1.5 billion theft from the Bybit exchange [25] came, according to forensic investigators, through a compromised wallet-software supplier.
- Google documented a 2025 voice-phishing campaign in which callers talked staff into connecting a malicious tool to Salesforce and stole customer data for extortion, without exploiting any software flaw or recording any AI use. [24] A July 2025 joint advisory by US, UK, Canadian and Australian agencies describes the same help-desk impersonation tactics in the Scattered Spider group's attacks. [101]
- In Brazil's instant-payment system, an IT employee at a connectivity provider allegedly sold his login for about US$2,700, and at least R$540 million was diverted. [26] At a second provider, about R$710 million of unauthorised transfers were made from two client institutions using its IT vendors' legitimate credentials; part has been recovered. [27]

OpenAI reported in October 2025 that attackers were building AI into existing workflows rather than gaining new offensive capabilities. [6] Anthropic found that GTG-1002 relied on commodity open-source tools rather than new exploits, while calling its level of autonomy "a fundamental shift" in how attackers use AI. [3]

Assessment: AI is an accelerant, not a new weapon class. It makes every existing weakness cheaper to find and faster to exploit. The practical consequence for a small country is the loss of protection through obscurity. When scanning and tailored deception cost a few tens of dollars per target, attackers no longer need to choose a market carefully. They can try everyone.

2. Chinese and open-weight models: a real risk, often misdescribed

Why "open-weight" is the issue

Closed models such as Claude, GPT and Gemini run on their developers' servers. Those developers can and do detect misuse: Anthropic detected the GTG-1002 campaign in mid-September 2025, investigated it over about ten days and banned the accounts involved. [3] An open-weight model's files can be downloaded and run on the attacker's own hardware. Its refusals can be removed, and nobody sees what it is asked to do. The UK AI Security Institute (AISI) notes that refusal training is "often easily reversible with access to the weights". [34] Most leading open-weight models in 2026 are Chinese: DeepSeek, Alibaba's Qwen, Moonshot's Kimi and Z.ai's GLM. [34, 36] Western open-weight models such as Llama, Mistral and OpenAI's gpt-oss carry the same structural risk.

Model and developer	Evaluator and date	Finding
DeepSeek R1-0528 (China)	US CAISI (NIST), Sep 2025	Under a common jailbreak, answered 94% of overtly malicious requests, against 8% for US reference models; agents were 12 times more likely to be hijacked [37]
DeepSeek R1 (China)	Cisco and University of Pennsylvania, Jan 2025	Blocked none of 50 harmful test prompts [39]
DeepSeek V4 Pro (China)	CAISI, May 2026	About 8 months behind the US frontier; 32% on a cyber benchmark against 71% for GPT-5.5 [38]
Leading open-weight models	UK AISI, Jul 2026	4-7 months behind closed frontier models on cyber, down from 6-10 months in 2025 [34]
Kimi K3 (China)	UK AISI and CAISI, Jul 2026	Completed a 32-step simulated corporate network attack in 1 of 10 attempts; "capable of autonomously attacking small, weakly defended and vulnerable enterprise systems, when directed to do so and given initial network access"; its safeguards did not prevent offensive attempts [35]
GLM-5.3 (China)	CAISI, Sep 2026	"The most cyber-capable open-weight model released to date", about 4 months behind the US frontier [36]
GLM-5.3 (China)	Anthropic, Sep 2026	Refusals fell from 95% to 6% after abliteration, costing an estimated US$1,200-4,400 of computing, with little capability loss. Anthropic is a commercial competitor [40]
Claude Mythos Preview (US, restricted release)	UK AISI, Apr 2026	First model to complete the same 32-step range, in 3 of 10 attempts [33]; by July 2026 the most capable closed models solved it in 6 and 7 of 10 attempts [35]

Benchmarks and simulated ranges differ; rows are not directly comparable. Capability "lags" are evaluators' estimates.

The economics favour attackers

Cost is where open-weight models change the arithmetic:

- AISI estimated a 100-million-token cyber-range run at about US$46 on GLM-5.2, against about US$85 on Anthropic's Opus 4.5/4.6. It also gave a figure of US$1.19 for DeepSeek V4-Pro. AISI cautioned that it did not run the open-weight models through their own developers' services, so real costs may vary; the DeepSeek figure is far below the BIS estimate below and is best treated as indicative. [34]
- The Bank for International Settlements (BIS) estimates that a full AI attack chain uses about 100 million tokens. That costs US$5,000-10,000 on Mythos Preview but "as little as $50-$100 per attack" on cheaper models. [43]
- In the September 2026 retail campaign, the average cost was US$25.46 per target scanned. [13]

- On criminal forums and Telegram, mentions of safety-stripped DeepSeek, GLM and Kimi models rose from about 11 to 93 posts a month between January and October 2026 (745%). Resold DeepSeek and Kimi access was advertised at about one-sixteenth and one-hundredth of official rates; GLM sold at a markup. [42]

Documented use in real attacks

The documented cases include:

- LAMEHUG malware, attributed with medium confidence to Russia's APT28, called Alibaba's Qwen at runtime through Hugging Face's hosted service. [7, 10]
- A Chinese-speaking actor used DeepSeek as an autonomous agent to find and attempt to exploit targets. Its autonomous exploitation attempts failed; the confirmed data theft came from manual work. [12]
- The September retail campaign used GLM and DeepSeek for vulnerability search and exploitation, with Anthropic's Opus 4.6 orchestrating and carrying out some of the hacking. [13]
- Google reports a suspected China-nexus group deploying a local open-weight model inside compromised cloud accounts, which lets it avoid commercial AI monitoring while using victims' computing power. [9]
- In South Korea, CrowdStrike linked a campaign against financial firms to the Chinese-developed ARTEX agent, with DeepSeek as its main model. CrowdStrike's attribution is moderate-confidence. A Korean security official said the AI "did not act independently without human involvement", and no Korean regulator has named a model. [14, 16]

The limits, stated plainly

The evidence also limits the claims:

- A randomised trial for AISI found no statistically significant uplift from chat-style AI on complete attack chains. RAND's follow-up, however, found that agentic tools (Claude Code running Anthropic's Opus and Sonnet 4.6) solved each of the same challenges in under an hour, for a total cost of less than US$20 across all of them. [41]
- Kimi K3 achieved arbitrary code execution on none of 41 exploit samples, against 20 for the strongest US models. [35]
- Every government cyber range so far has lacked active defenders, so success against well-monitored networks is unproven. [33, 44]
- The September retail operator still typed about 1,951 instructions across 260 sessions. [13]
- The Latin American bank-targeting framework relied mainly on closed US models; its Kimi fallback refused offensive requests. [17]
- Several sources have commercial or political interests. The BIS records accusations that Anthropic amplified fear around Mythos. [44]

Defenders' access is not equal

The most capable defensive models are being shared selectively. In June 2026 Anthropic's restricted Glasswing programme added about 150 new organisations, based in more than 15 countries, to roughly 50 initial partners. No Caribbean country or organisation has been named among them. A US export-control directive cut non-US access to Anthropic's most capable models from 12 June to 1 July 2026. [44, 46] Anthropic's broader Cyber Verification Program, expanded in October 2026, lists no country restriction for its defensive tier, though its top tier is reviewed with the US government. [46] The Financial Stability Board (FSB) Chair warned the G20 that differences in cyber capability across jurisdictions "may themselves become a source of vulnerability". [45]

Assessment for T&T: three consequences follow.

1. The safety controls built by US AI companies cannot be relied on to slow attackers.
2. The cost of attempting an attack has fallen to tens of dollars, so small markets are now worth scanning.
3. A four-to-eight-month capability lag is shorter than the time many institutions take to replace legacy software. In practice, what only the leading models can do today is likely to be within reach of freely available models within a

year.

3. Trinidad and Tobago's track record

The incidents on the public record

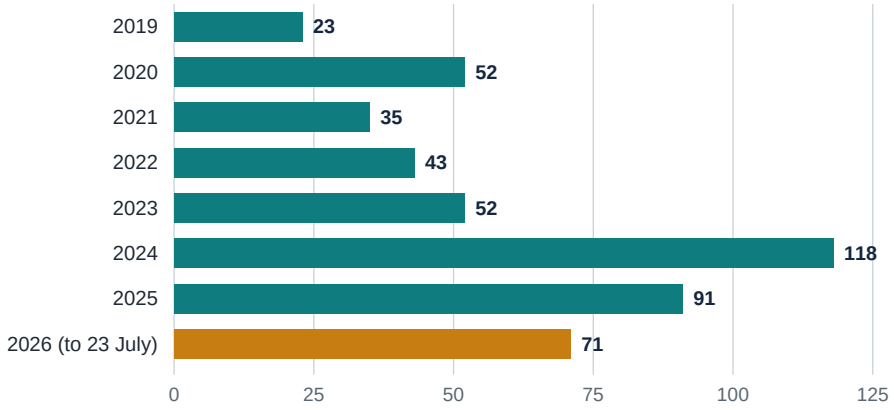
Date	Organisation	What happened
Apr 2022	Massy Stores	Ransomware closed stores and disrupted card payments; the Hive group claimed the attack [47]
Jun-Jul 2023	Office of the Attorney General and Ministry of Legal Affairs	Network intrusion; electronic court filings and government lawyers' email disrupted [48]
Oct 2023	TSTT	RansomEXX ransomware; customer data including identity-document scans leaked. An interim forensic report found the attackers used an administrator's credentials; TSTT has published no forensic report [49]
Dec 2023	National Insurance Board (NIBTT)	Ransomware closed all offices from 27 to 29 December [50]
2019-2023	Four insurers	Reported ransomware (2019 and 2023), malware (2021) and a data breach (2022) [63]
Jun 2025	CIBC Caribbean, Trinidad operation	The managing director reportedly authorised 19 transfers totalling about $14.8 million (currency not stated) to Hong Kong, Singapore and Bulgaria on WhatsApp and email instructions that appeared to come from the chief executive; about $9.4 million was unaccounted for when reported. The bank's FY2025 annual report confirms a loss from "a fraud incident in Trinidad". No AI use was reported [53, 54]
Jul 2025	Venture Credit Union	Ransomware; members' personal documents leaked. The credit union said core banking data was not compromised; local reporting attributes the attack to the Qilin group [51]
2025-2026	Public figures	Deepfakes of the Prime Minister, the Minister of Finance, the Fair Trading Commission chairman and a former President promoted fraudulent investments [59, 75]
Disclosed Mar 2026	National Quarries Company	Malware destroyed accounting software, delaying audited accounts by years [55]
Jun 2026	Customer of a local commercial bank	Three accounts emptied over two days (24-25 June): over TT$1 million plus nearly US$100,000, partly recovered. The bank and the method have not been disclosed [56]

What the numbers say, and what they cannot say

Indicator	Value	Caveat
Incidents reported to TT-CSIRT	52 (2023), 118 (2024), 91 (2025), 71 (to 23 July 2026). Of 485 since 2019, 296 were phishing or business email compromise and 43 ransomware	Counts only incidents organisations chose to report; private firms made 12 of the 118 reports in 2024; no loss data [62, 77]
FIUTT suspicious transaction reports, Oct 2024-Sep 2025	1,523 reports worth TT$1.254bn, of which TT$762.7m completed; 59% suspected fraud, "majority being online scams"	Suspicions reported, not confirmed losses [58]
TTPS Fraud Squad reports, Jan-Jul 2026	551 reports with reported value of $167.4m, up 227% from $51.2m a year earlier	All fraud types, including $78.9m of fraud against government institutions (the article also gives $91.7m for this category); reported values, not confirmed losses [57]

Indicator	Value	Caveat
Ransomware leak-site listings, T&T	4 (2023), 4 (2024), 5 (2025), 0 (Jan-Jun 2026)	Victims who pay are often not listed; the consultant estimates at least twice as many breaches as listings in 2025 [52]
Ransomware leak-site listings, Caribbean	32 (2023, wider scope), 13 (2024), 21 (2025), 21 (Jan-Jun 2026)	Finance and investment tied for most-targeted sector in early 2026 [52]

Cyber incidents reported to TT-CSIRT | number per year (2026 to 23 July)



The data are better than they first appear, but they still cannot measure harm:

- TT-CSIRT's statistics page publishes a yearly series of reported incidents. The page draws its figures with scripts, so a plain download shows empty placeholders. The series matches the Central Bank's published totals. [63, 77]
- The series counts only incidents organisations choose to report; there is no legal duty to report to TT-CSIRT. [79] Public bodies made 106 of the 118 reports in 2024 and private firms 12, which most likely reflects private-sector under-reporting rather than private-sector safety. [77]
- The Central Bank has required licensees to report material cyber incidents since 2023 but has published no counts from that regime. [64, 65]
- Police figures disagree with each other. TTPS crime statistics record 399 fraud offences for January-July 2025, against 819 reports to the Fraud Squad over the same months. [57, 99]
- A press report of an October 2025 Central Bank meeting attributed to the Governor a figure of about $3.3 million lost to online fraud in a year. The Bank's own release gives no figure, and the number probably covers a narrow reporting channel. [61, 69]
- No source publishes total losses from cyber incidents or cyber-enabled fraud.

A country that counts only the incidents reported to it, and publishes no loss figures, cannot tell whether its defences are working.

Reading the record

Three patterns stand out.

- **Entry has mostly come through people and credentials.** At TSTT it was an administrator's account. At CIBC it was impersonation of the chief executive. Police now warn about unexpected one-time-passcode prompts leading to account hijacking. [57]
- **The disruptive intrusions have concentrated on the periphery.** Telecoms, government agencies, four insurers, a credit union and retailers have been hit. No commercial bank's core systems are publicly known to have been breached, although the largest documented loss, at CIBC, was taken from a bank through one of its executives. That pattern is consistent with attackers taking the easiest route. Given mandatory incident reporting to the Central Bank, it is neither proof that banks are hardened nor evidence that they are weak.

- **The CIBC case is the template AI makes cheaper.** Arup and Fideuram show the same playbook, with a cloned voice or a fake video call added on top of message-based impersonation. [18, 19, 53]

Geopolitical exposure has also risen. Trinidad and Tobago backed the 2025 US naval campaign. Venezuela declared the Prime Minister persona non grata in October 2025, and US forces captured Nicolás Maduro on 3 January 2026. [31, 32] The documented cyber activity in that crisis was aimed at Venezuela. This research found no confirmed spillover attacks, and no documented hacktivist campaign, against T&T or Caribbean financial institutions. The region is nonetheless busy: Latin America was the most-attacked region in Check Point's telemetry in September 2026. SIM-swap services are openly advertised to criminals, and Recorded Future assesses that AI lets them write convincing phishing in native Spanish and Portuguese. [29, 30]

4. The rulebook: Central Bank regulation and supervision

The Central Bank of Trinidad and Tobago (CBTT) has built the only working cyber rulebook in the financial sector. Measured against the "second generation" of bank cyber regulation that was common by 2023, it is respectable. [96] Measured against what changed in 2026, it has moved little.

Instrument	What it does	Assessment
Cybersecurity Best Practices Guideline (Sep 2023)	20 requirements across governance, risk management, training, continuity, testing and incident management, with annual self-assessments signed by the chief executive [64]	Principles-based. Customer multi-factor authentication, patch management and information sharing sit in a section of practices that are "recommended but which are not essential to comply". Patches are due "within a timeframe that is commensurate with the criticality", with no deadline. The guideline does not mention AI, although the Bank's updated risk-based supervision framework (effective 1 October 2025) names technology and cyber as key risks and AI as a new risk supervisors should assess. Breaching a guideline is not an offence, but the CBTT can issue compliance directions [64, 67, 72]
Mandatory incident reporting (guideline Appendix II, Sep 2023; restated in a circular dated 5 Feb 2025)	Initial notice within 24 hours, full report within 72 hours, regular updates and a lessons-learned report. Covers banks, insurers, payment operators and e-money issuers, and explicitly includes social engineering that leads to unauthorised wire transfers [64, 65]	Meets common international timing: New York and Jamaica require 72 hours [88, 89]. Barbados requires classification within 24 hours of detection and an initial report within 4 hours of classifying an incident as major, so its clock can run faster but has a similar outer limit [87]. The 2025 circular was posted publicly about five months after it was issued
Annual self-assessment with action plans and independent review [65]	Annual tracking of gaps	Aggregate results have never been published
Cybersecurity supervision framework	Policies for off-site monitoring and on-site examinations [67]	Described as "developed" but not published. One joint IT and cyber on-site examination, of a large bank, was conducted in FY2024/25 [67]
Payment system operator licensing (effective 29 Sep 2026)	Applies international payment-infrastructure standards, including cyber resilience guidance and a 2-hour recovery target [70]	Strong on paper. Written for initial licensing, with no stated transition for incumbent operators. Significant retail systems need meet critical standards only "partially" [70]
Strategic Plan 2026/27-2030/31 (Oct 2026)	Names "the AI-cybersecurity nexus" and third-party technology concentration as emerging risks, and promises an AI "guiding framework" for the sector [68]	None of its 23 projects is dedicated to cyber supervision, although one covers system-wide resilience testing and contingency planning; climate risk receives its own supervisory framework project [68]

Evidence from the Central Bank's own reviews

The CBTT's 2022 thematic review covered 7 of the 8 commercial banks:

- Three had no clearly documented, board-approved information-security strategy.
- There was "no formal evidence of threat information sharing among the commercial banks".
- Three banks used the same managed security provider, a concentration risk.
- Foreign-owned banks' cybersecurity was largely driven by their parent groups.

The review relied on self-assessments and interviews; it did not test whether controls worked. [66] The latest Financial Stability Report, covering 2024, rates sector cyber risk "elevated" and cites a shortage of skilled cyber professionals. [62] Its 2025 successor had not been published by 28 October 2026.

What the Central Bank has done

The Bank deserves credit for steady groundwork:

- The IMF described it in 2024 as "proactive in raising awareness and strengthening cybersecurity practices". [81]
- It received IMF technical assistance on cyber regulation and supervision and has trained its examiners in cyber risk. [62]
- Licensees began reporting material incidents in 2023-24. The Bank has since issued a standard reporting form and, in July 2025, surveyed commercial banks on electronic fraud. [67]
- It hosted a cyber-range exercise and an AI and cyber-resilience webinar with the BIS. [67]
- In October 2025 it convened banks, police and FIUTT on online fraud. In April 2026 it held a public session on cyber threats and fraud with BATT and TTSEC. [69, 100]
- Its 2026 payment-operator licensing rules adopt international cyber-resilience standards. [70]
- In November 2024, CARICOM central bank governors, the CBTT among them, signed an agreement to share cybersecurity information. [62]

The missing response to frontier AI

After Mythos Preview was announced on 7 April 2026, financial authorities in at least eleven, mostly advanced-economy, jurisdictions issued letters, statements, inspections or task forces. Most asked firms to apply existing controls faster rather than imposing new rules. [44] Examples:

- The Bank of England, the FCA and HM Treasury asked firms to remediate vulnerabilities "more quickly, more frequently, and at scale". [90]
- New York's financial regulator set out about twenty heightened-threat measures, including phishing-resistant MFA and rapid remediation of internet-facing flaws. [89]
- Canada's OSFI urged institutions to consider accelerating patch management. [94]

No Caribbean supervisor, including Barbados and Jamaica, appears among the jurisdictions the BIS lists as having responded publicly. [44] Both had, however, moved earlier on the fundamentals:

- Barbados revised its technology and cyber-risk guideline in March 2026, just before Mythos was announced. It includes an AI section, a 4-hour initial report once an incident is classified as major, annual penetration testing and threat-led testing. [87]
- Jamaica launched a sector-wide cyber-intelligence sharing hub in 2025. [88]

The CBTT posted roughly 80 circulars and regulatory notices between January and October 2026. None was a supervisory communication on cyber or AI risk. Its 2026 cyber output was the April public session, the payment-operator licensing standards and a strategic plan that names the AI-cybersecurity nexus. **On public evidence, Trinidad and Tobago's financial supervisors have not yet issued guidance on the frontier-AI shift that at least eleven larger jurisdictions addressed in 2026; no other Caribbean supervisor has done so publicly either.** A private letter to institutions cannot be ruled out: the CBTT posted its February 2025 cyber circulars publicly about five months after issuing them.

Outside the Central Bank's reach

- **Credit unions:** an estimated TT$18.5 billion of assets, about 11% of commercial-bank assets. The CBTT's figure is labelled an estimate and has not changed since 2021, which suggests it has no current data. Credit unions are registered with the Commissioner for Co-operative Development and supervised by FIUTT for anti-money-laundering purposes, but neither applies prudential or cyber standards. A 2024 proposal for an independent supervisor has not advanced, and this research found no statutory deposit-insurance scheme for them. [58, 71, 81]
- **Securities firms:** the Securities and Exchange Commission (TTSEC) has issued no cybersecurity guideline for registrants. It treats cyber risk as an emerging risk within supervision. [95]

5. National law and institutions

Area	Status at 28 October 2026	Consequence
Cybercrime law	The Computer Misuse Act 2000 remains the main statute. The Cybercrime Bill 2017 went to a joint select committee and was never enacted. None of the 44 bills in the current Parliament concerns cybercrime [73]	Outdated offences and investigative powers; accession to the main international cybercrime convention (Budapest) is out of reach without new law
Data protection and breach notification	The Data Protection Act 2011 is only partly in force. The obligations on private organisations (Part IV) and most obligations on public bodies (Part III) were never proclaimed. The Act has no breach-notification duty [74]. The FY2027 budget calls modernisation "well advanced" [76]	No statutory duty to tell customers when their data is stolen. CBTT licensees must report incidents to the CBTT and are expected, without a statutory basis, to inform affected customers; telecom operators must notify TATT
National strategy	The National Cyber Security Strategy dates from 2012 [77]	No current national plan for AI-era threats
National incident response team	TT-CSIRT operates on an administrative basis under the Ministry of Homeland Security. It published nothing between 25 September 2025 and 13 March 2026. It has since issued nine advisories in 2026, including on actively exploited firewall and VPN flaws, but none on Citrix NetScaler since July 2024, despite three exploited waves since. It publishes counts of reported incidents but no loss data [77]	Uneven early warning for exactly the kind of fast-exploited flaw AI agents use
Cyber agency	The Cyber Security Agency Bill (2015) was never passed [73, 77]	No statutory coordinator
AI and cyber coordination	Cabinet approved an inter-ministerial steering committee on cybersecurity and AI on 11 September 2025 and endorsed a five-year "national cybersecurity and AI safety framework" [75]	No report or framework text had been published by October 2026
Fiscal support	The cybersecurity investment tax allowance (up to TT$500,000) appears to have lapsed on 31 December 2025. The FY2027 budget mentions cybersecurity only for virtual-asset licensing [76]	Weaker incentive to invest in security
Telecoms	The regulator TATT's January 2026 framework requires 24-hour incident notice. It explicitly allows SMS one-time codes and contains no SIM-swap control [80]	Banks' most common second factor rests on an unregulated weak point

International indices agree:

- The ITU's Global Cybersecurity Index 2024 places Trinidad and Tobago in Tier 3, "Establishing", at about 56 out of 100. It is weakest on legal measures (8.9 of 20) and technical measures (7.0 of 20). [78]
- The National Cyber Security Index scores the country 35.8 and ranks it 110th. It scores zero on incident-reporting obligations, on identifying critical information infrastructure and setting requirements for it, and on cybercrime offences and procedural law. It gives full marks for national incident-response capacity, cyber-threat analysis and cybercrime-investigation capacity. [79] The gap is law and mandate more than operational skill.
- A 2025 IDB-OAS review ranked Trinidad and Tobago among the three most mature Caribbean states, but no Caribbean country reached the top stage in any dimension. [93]

There has been some activity:

- a TT-CSIRT agreement with TATT on telecom threat sharing (March 2026);
- a letter of intent with a regional cyber competence centre (July 2026);
- engagement with CARICOM IMPACS;
- foundational training for 40 young people. [77]

The Bankers Association (BATT) used its budget response to urge full proclamation of the data-protection and electronic-transactions laws. [98] **Still, the national legal framework has barely moved since 2017.**

6. What institutions and shared infrastructure show in practice

A large, concentrated, well-capitalised system

- **Size:** domestic financial-sector assets were TT$374.0 billion at end-2024. Banks, insurers and pension funds held 77.5% of that, equal to 166.2% of GDP. [62]
- **Banks:** eight commercial banks held TT$166.6 billion at end-2025. [71] Two are designated domestically systemically important. [62]
- **Capital:** banks are well capitalised, with a capital adequacy ratio of 18.2% in December 2024. [62]
- **Loss-absorbing capacity:** a single fraud loss of a few million dollars does not threaten solvency. **The cyber risk to this system is not insolvency. It is outages, stolen data, eroded trust and losses that fall on customers and smaller institutions.**

Customer protection: what banks publicly describe

Institution	Publicly described controls	Gap against leading practice
Republic Bank	Second factor by SMS code, app code or app approval; retail third-party transfers capped at TT$50,000; beneficiaries must be pre-registered	SMS remains selectable; no confirmation of payee or new-payee delay described
Scotiabank T&T	Biometric sign-in, hardware and software tokens, two-step codes; reimbursement guarantee if customers meet their security obligations	No confirmation of payee or new-payee delay described
CIBC Caribbean	One-time code needed to add a payee; its 2025 annual report says it expanded MFA and adopted "zero-trust" defences group-wide [54]	No account-name confirmation described
ANSA Bank	A code sent to the customer's mobile phone for every online transaction	Relies on phone-delivered codes
First Citizens, RBC Royal Bank	Not verified: their websites blocked automated review	Not assessed

Source: banks' public security pages and annual reports [54, 83]. Public pages do not prove the absence of internal fraud controls.

New York's regulator advises firms to consider avoiding SMS, voice or video as authentication factors because AI deepfakes can defeat them. [89] US cyber authorities have told users not to rely on SMS as a second factor after Chinese state actors penetrated telecom networks. [28] In Trinidad and Tobago, the mobile market is a near-duopoly with a concentration index of 5,014, and 79% of lines are prepaid. [80] The 2023 TSTT leak exposed identity scans and phone numbers [49], the kind of personal data used in SIM-swap fraud. This research found no public information on SIM-swap controls at either operator.

Boards, skills and insiders

Governance evidence is thin and mixed:

- First Citizens, one of the few banks to publish a director skills matrix, rates none of nine directors "very skilled" in IT or cybersecurity: four are rated moderately skilled and five as having no skill. It also makes cybersecurity, including AI, a mandatory staff training topic. [84]
- Republic's board training in 2025 focused on cybersecurity strategy and AI. [83]
- In a survey of 105 Caribbean directors across all sectors, only 16% said their boards strongly understood cybersecurity's strategic importance, and 31% of boards never received cyber reports. [82]

Insider risk also matters, and AI does not remove it. In November 2025 a court found a former ANSA Bank officer liable for a scheme of sham vehicle loans worth about TT$30 million and said the bank should have had better internal systems. [60] That was a lending-control failure rather than a cyber attack, but the lesson carries over: limit what any one trusted person can authorise.

Information sharing

BATT has security and cybersecurity committees with one representative per bank. [85] This research found no public evidence of a formal local threat-sharing platform among the banks. The CBTT's 2022 review found that six of seven banks subscribed to external sources such as FS-ISAC, but shared little with each other, and its guideline only encourages an "informal" group. [64, 66] Jamaica now runs a sector-wide sharing hub. Its central bank partly attributes an 18% fall in reported bank fraud in 2025 to information sharing and stronger rules. [88]

Shared infrastructure: the system's single points of failure

Infolink Services, owned by First Citizens, RBC, Republic Bank and Scotiabank, runs three of the four interbank payment systems:

- the LINX debit network, switching more than 39 million transactions a year;
- the automated clearing house (ACH);
- electronic cheque clearing. [70]

The ACH processed 20.4 million transactions worth TT$182.7 billion in 2024, roughly **TT$730 million per business day**. [62] Infolink has published no incident disclosures and no public assessment against international payment-infrastructure standards. [70]

On 22 October 2026, Jamaica's equivalent operator, JETS, disclosed a breach of its administrative systems that may have exposed card numbers and payee names. Its payment networks kept running. [88] It is the closest regional warning yet.

Other concentrations:

- the managed security provider shared by three banks in 2022 [66];
- reliance on a small number of third-party digital service providers, which the CBTT itself flags [62].

Parent groups help some banks, not all

The protection that comes from a parent group is real but uneven:

- RBC and Scotiabank's Canadian parents fall under OSFI, which issued a frontier-AI bulletin in 2026. [94]
- Barbados's March 2026 guideline must be applied by Barbados-headquartered banking groups in their foreign subsidiaries. [87] That appears to cover CIBC Caribbean's Trinidad bank, whose parent will change if Butterfield's agreed acquisition completes, which is expected in the first half of 2027. [86]
- Republic Bank and First Citizens, the largest locally owned banks, have no foreign parent to lean on.

Buffers that help

Several features limit the damage an attack can do:

- Banks have completed migration to chip cards. [62]
- Cash remains widely used, with TT$36.6 billion withdrawn from ATMs in 2024. [62]
- E-money is still small, at TT$0.12 billion of transactions in 2024. [62]

These limit the reach of an attack on digital payment channels. Foreign exchange scarcity cuts the other way. The CBTT sold US$400 million to dealers in January-April 2026, and reserves fell from 8.0 to 5.8 months of imports between late 2024 and mid-2026. [71] Security tools, managed services and specialist staff are largely priced in US

dollars. Limited foreign exchange makes defences harder to buy.

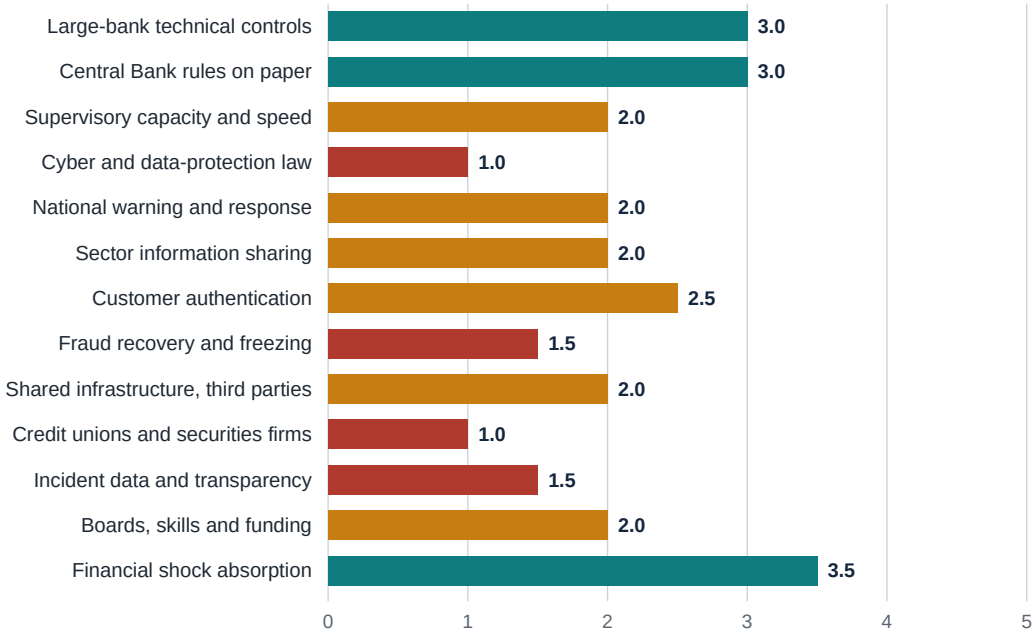
7. Readiness scorecard

Each domain is rated from 1 to 5 against the international practice described in this report: [43-45, 87-91]

- **1:** absent, or a major gap.
- **2:** early or partial.
- **3:** broadly meets a 2023-era baseline.
- **4:** largely meets current practice.
- **5:** comparable with leading jurisdictions.

The ratings are analytical judgments from public evidence and are not weighted. **The scorecard mainly measures the framework around institutions**: law, supervision, data and shared arrangements, plus what institutions disclose. It does not measure tested defensive capability, which public sources cannot show.

Readiness scorecard | 1 = absent or major gap, 3 = 2023-era baseline, 5 = leading practice



Domain	Rating	Basis
Technical controls at the largest banks	3.0	International frameworks, 24x7 monitoring and, for foreign-owned banks, parent-group programmes reported; SMS codes and limited payee verification persist [66, 83]
Central Bank rules on paper	3.0	24/72-hour reporting since 2023, self-assessment and testing expectations; key controls only "recommended"; AI named as a supervisory risk but absent from the cyber guideline [64, 65, 67]
Supervisory capacity and speed	2.0	Self-assessments, incident reporting, an e-fraud survey and examiner training; but one joint cyber examination in a year, an unpublished framework and no public response to frontier AI [62, 67, 68]
National cyber and data-protection law	1.0	Cybercrime bill lapsed; data-protection obligations unproclaimed; no breach-notification law [73, 74]
National warning and incident response	2.0	Real operational capacity and 2026 advisories; but no legal mandate, a five-month publication gap and missed NetScaler waves [77, 79]
Sector information sharing	2.0	Industry committees, a Central Bank-convened fraud group and regional agreements; no formal local platform [62, 66, 69, 85]

Domain	Rating	Basis
Customer authentication and payment controls	2.5	Multi-factor login is common and some banks offer tokens or app approval; SMS codes remain widely used or selectable; no confirmation of payee described [83]
Fraud recovery and cross-border freezing	1.5	Coordination began with the Central Bank's October 2025 meeting, but no protocol has been published; a business chamber called for one in 2026 [56, 69]
Shared infrastructure and third parties	2.0	New payment licensing standards; incumbent switch's resilience unpublished; concentration noted [66, 70]
Credit unions and securities firms	1.0	No credit-union prudential or cyber supervisor; no securities cyber guideline; a credit union hit by ransomware. Insurers fall under the Central Bank's rules and are scored with them [51, 58, 81, 95]
Incident data and transparency	1.5	TT-CSIRT publishes counts of voluntarily reported incidents, but private firms rarely report, the Central Bank publishes nothing from its own reporting regime, police series conflict and no loss data exist [57, 77, 99]
Boards, skills and funding	2.0	Board skill gaps; staff shortages; lapsed tax allowance; foreign-exchange constraints [62, 71, 76, 82, 84]
Financial shock absorption	3.5	Strong capital, chip cards and a cash fallback; but a narrowing liquidity buffer, heavy sovereign exposure and foreign-exchange pressure [62, 71]
Unweighted average	**2.1**	**Not ready for a determined AI-assisted group; partly ready for routine crime**

The result is not sensitive to individual judgments: moving any five domains by half a point in either direction changes the average by about 0.2.

The pattern is clear. Defences are strongest where capital rules and, for foreign-owned banks, parent-group programmes do the work. They are weakest wherever national government action is required.

How Trinidad and Tobago compares with two Caribbean peers

Measure	Trinidad and Tobago	Barbados	Jamaica
Bank incident-reporting clock	24-hour notice and 72-hour report (since 2023) [64, 65]	Classify within 24 hours; initial report within 4 hours of classifying an incident as major [87]	72 hours [88]
AI addressed in cyber rules	No; AI is named only as a general supervisory risk [64, 67]	Yes: AI and machine-learning section (March 2026) [87]	Not reviewed
Required penetration testing	Testing "commensurate" with risk; threat-led testing "where necessary and appropriate" [64]	Annual tests of internet-facing systems; full-scope tests every two years; threat-led testing [87]	Annual tests; full-scope tests every two years [88]
Sector threat-sharing platform	None found [66, 85]	Not reviewed	Yes, established 2025 [88]
Public frontier-AI response (BIS list)	No [44]	No [44]	No [44]

Selected measures only; "not reviewed" means this research did not establish the position, not that the measure is absent.

Trinidad and Tobago's bank reporting clock is comparable with its neighbours'. On testing requirements, AI-specific rules and information sharing, Barbados and Jamaica have moved further.

8. How an AI-armed group would most likely attack, and what would happen

The question is not whether a group could break into Trinidad and Tobago's best-defended bank core. It is which route a rational attacker would choose, and how the system would respond. The table describes likely routes at a strategic level only.

Attack route	Why it fits T&T	Likelihood (12 months)	Impact	Readiness
Impersonated or deepfaked executive orders urgent payments	Already happened at CIBC (2025); deepfakes of ministers are common; Fideuram shows the AI version	High	Millions of dollars per case; reputational damage	Low to medium: depends on each bank's call-back rules; no sector standard
AI-written phishing, texts and calls lead to account takeover via stolen codes or SIM swaps	Phishing drove the 2024 doubling in incidents; SMS codes are widespread; TSTT leak data exist	High	Many individual losses, with elderly customers a particular concern; erosion of trust	Low
Rapid exploitation of an unpatched internet-facing system at a credit union, insurer, broker or vendor, followed by ransomware or extortion	Venture Credit Union and insurers already hit; the Korean "side-door" pattern; national advisory gaps	High	Outages lasting days to weeks; data leaks	Low
Deepfake or synthetic identities used to open accounts for laundering	FIUTT reports a rise in onboarding fraud; digital account opening is spreading [58]	Medium to high	Laundering; damage to international standing	Low: FIUTT's advisory does not address liveness or deepfake detection
Compromise of a shared provider such as a payment switch, core vendor, security provider or telecom	Infolink concentration; the JETS breach; three banks sharing a security provider	Low to medium	Potentially system-wide	Unknown; low on public evidence
AI-assisted intrusion into a large bank's core network	GTG-1002 targeted financial institutions; AI lowers the cost of trying	Low to medium	High	Medium
Politically motivated disruption linked to regional tensions	Venezuela-related tensions since 2025	Low	Medium to high	Low to medium

Likelihood and impact are analytical judgments, not probabilities. Readiness reflects public evidence only.

The most likely damage is not a single dramatic heist. It is a steady and probably rising flow of impersonation fraud and account takeovers, with occasional ransomware at the periphery, each individually survivable. Together they drain customers, burden police and erode confidence in digital banking just as the CBTT plans an instant-payment system and a fully digital payments system by 2035. [70]

The tail risk is an outage at shared infrastructure. A multi-day failure of the ACH or the LINX network would interrupt salaries, bill payments and card transactions across all participating banks. The cash fallback would limit, but not eliminate, the harm. Abroad, ransomware took a US$9 billion California credit union's online banking offline for more than two weeks, and customers reported ATM withdrawals limited to US$500. [97] A similar event at a large local credit union or insurer is plausible.

9. What would make Trinidad and Tobago ready

Most of the required measures are rules and coordination, not expensive technology. The binding constraints are political priority, legislative time and specialist staff.

Within three months: no new legislation needed

Action	Responsible	Why
Issue a frontier-AI supervisory letter requiring accelerated patching of internet-facing systems, inventories of exposed devices, tested backups and board briefings	CBTT, TTSEC	At least eleven, mostly advanced-economy, jurisdictions issued letters, statements, inspections or task forces in 2026, mostly asking firms to apply existing controls faster [44, 89, 90]
Set a sector standard for payment instructions: independent call-back verification for urgent, executive or new-beneficiary payments above a threshold; no approval on WhatsApp or email alone	CBTT with BATT	Directly targets the CIBC and Fideuram pattern [19, 53, 92]
Create a 24/7 rapid fraud-freeze protocol among banks, police and FIUTT, including templates for cross-border recall requests	CBTT, BATT, TTPS, FIUTT	Singapore and Hong Kong police recovered essentially all of a US$499,000 deepfake-induced transfer through fast cross-border cooperation [20]; a local business chamber has asked for exactly this [56]
Publish aggregate incident and fraud statistics	CBTT, TT-CSIRT, TTPS	Turns anecdotes into evidence and lets progress be measured

Within twelve months

- **Law:** enact a modern cybercrime law and proclaim the Data Protection Act with mandatory breach notification. Give TT-CSIRT a statutory mandate, staff and budget, including national exposure feeds so owners of vulnerable systems are warned within hours.
- **Customer authentication:** require phishing-resistant MFA for staff privileged and remote access. Phase out SMS codes for high-risk customer actions such as adding a payee, raising limits or changing devices. Build confirmation of payee into the planned instant-payment system before launch, not after.
- **Patching:** set deadlines for actively exploited, internet-facing vulnerabilities measured in days rather than "commensurate" timeframes.
- **Sharing:** build a sector threat-sharing hub on Jamaica's model, covering banks, insurers, credit unions, Infolink and the telecom operators. [88]
- **Testing:** require threat-led penetration testing for the systemically important banks and Infolink. Apply the new payment-infrastructure cyber standards to incumbent operators.
- **Periphery:** bring credit unions under prudential and cyber supervision. Encourage pooled security monitoring for small credit unions and insurers that cannot afford their own.
- **Telecoms:** have TATT require SIM-swap controls and a way for banks to check whether a SIM was recently changed before trusting an SMS code.
- **Defensive AI:** seek access to AI developers' defensive programmes, individually or through regional bodies, and use AI for fraud detection and patch prioritisation.
- **Exercises:** run a sector-wide exercise that combines ransomware at a shared provider with deepfake payment fraud, and publish the lessons.

10. What to monitor, and the final judgment

Indicator	Why it changes the assessment
A CBTT or TTSEC communication on frontier AI	The clearest signal that supervisors have registered the 2026 shift
Publication of the 2025 Financial Stability Report with incident counts	Tests whether the Central Bank will publish regular counts from its own incident-reporting regime
A cybercrime bill tabled; Data Protection Act proclaimed with breach notification	Determines whether the national framework moves at all
Private-sector reports to TT-CSIRT, and timely advisories on exploited edge devices	Measures national visibility and early warning
Credit-union supervisory legislation	Closes the largest unsupervised segment
Findings on Jamaica's JETS breach (a minister set JETS a 31 October 2026 deadline for a written report; publication is not assured) [102]	Would show how a regional payment switch was entered and what Infolink should check
Bank authentication changes: SMS phase-out, confirmation of payee	Shows whether customer-facing defences are adapting
Police fraud values and ransomware listings	Shows whether the attack volume is rising or being contained
Any attributed AI-enabled incident in the Caribbean	Converts a projected threat into a demonstrated one

Final judgment

On public evidence, Trinidad and Tobago's financial system is not ready for a hacker group equipped with current AI models, including freely available Chinese open-weight models. The reason is not a lack of capital or the absence of any rules. The largest banks are well capitalised and subject to a Central Bank guideline and a 24/72-hour incident-reporting rule that compare reasonably with 2023 international practice. The foreign-owned banks also draw on parent-group security programmes.

The weakness is the system around them:

- a cybercrime law from 2000 and a data-protection law left mostly unproclaimed since 2012;
- incident statistics that capture few private-sector incidents and no losses;
- a supervisor with no public response to frontier AI;
- no formal local threat-sharing platform;
- a large credit-union sector outside prudential and cyber supervision;
- customer security that still often relies on SMS codes.

AI multiplies exactly these weaknesses. It makes impersonation more convincing, scanning cheaper and exploitation faster. Open-weight models remove one external check: the AI developer's ability to spot and stop misuse, which so far has worked mainly after the fact.

The evidence does **not** show that a successful AI-driven attack on a local bank has occurred, that open-weight models outperform US models, or that a systemic cyber crisis is imminent. Losses to date have been material but not systemic, and strong capital and a cash fallback limit the damage to the financial system itself. Nor can public evidence show how well individual banks would hold up. Determined groups have breached financial institutions in far larger and better-resourced systems, so readiness is a matter of degree everywhere.

The appropriate conclusion is a large and widening readiness gap in the framework around the financial system. The cheapest fixes are regulatory and organisational, and could begin within weeks. Every month without them leaves attackers' falling costs to meet defences that are changing only slowly.

Sources, methods and verification

Evidence boundaries

The report uses public research, official statistics, regulator and parliamentary documents, company disclosures, and threat reports from AI developers and security firms. Research was completed on 28 October 2026. No institution was contacted, tested or given an opportunity to comment, and no confidential supervisory information was available. Absence of a public incident does not mean absence of an incident: ransomware victims who pay are often not listed, and there is no general breach-notification duty.

Several source types have interests to weigh:

- AI developers' threat reports (Anthropic, OpenAI, Google) describe misuse of their own products, and the developers compete commercially with Chinese labs.
- Security vendors sell defensive products.
- Government evaluators frame some findings in terms of US-China competition.
- Criminal-market prices and victim counts are often self-reported by attackers.

Figures reported in different currencies or without a stated currency are given as published. Local police and court figures reported in dollars are taken to be Trinidad and Tobago dollars, following local convention. The CIBC loss is reported without a currency. Where sources conflicted, the report uses the primary source and notes the conflict.

TT-CSIRT's incident counts were read on 28 October 2026 from the data embedded in its statistics page, which draws the figures with scripts. A plain download of the page shows only empty placeholders.

The research and fact-checking for this report were carried out with the help of AI research agents built on Anthropic's Claude models. Anthropic's own threat reports and model evaluations are among the sources. Factual claims were checked against their cited sources in independent verification passes, and the conclusions are the author's.

Calculation conventions

Calculation	Definition
ACH value per business day	TT$182.7bn / 250 business days = approximately TT$730m. The business-day count is an assumption.
Credit-union share	TT$18.5bn estimated credit-union assets / TT$166.6bn commercial-bank assets = approximately 11%. Both figures are for 2025, but the credit-union figure is a CBTT estimate unchanged since 2021.
TT-CSIRT totals	23 + 52 + 35 + 43 + 52 = 205 for 2019-2023, matching the Central Bank's figure; adding 118 (2024), 91 (2025) and 71 (to 23 July 2026) gives 485.
Global Cybersecurity Index total	Sum of five ITU pillar scores: 8.88 + 6.98 + 16.21 + 13.03 + 11.13 = 56.23.
Korean deficiency share	130 / 555 firms = 23.4%.
Fraud Squad change	$167.37m / $51.15m - 1 = +227%.
Scorecard average	Unweighted mean of 13 domain ratings = 27 / 13 = 2.1.
Scorecard sensitivity	Five domains x 0.5 points / 13 domains = about 0.2 change in the average.

Scorecard method

Domains were chosen to cover the controls that international authorities emphasised in 2026: governance, patching speed, authentication, response and recovery, third-party concentration, information sharing and incident reporting. Ratings compare public evidence on Trinidad and Tobago with the practices in the cited international and regional sources. Missing information counts against a domain only where the missing item is itself a control, such as a published statistic or a written rule. The scorecard therefore measures the framework and what is disclosed, not tested defences. A different weighting, or confidential evidence, could change individual ratings. It is unlikely to change the overall conclusion, which rests on documented gaps in law, data and supervisory response.

References: AI-enabled attacks and the global threat

[1] Microsoft Threat Intelligence (14 February 2024), *Staying ahead of threat actors in the age of AI*, research with OpenAI; Infosecurity Magazine coverage. Microsoft · Infosecurity Magazine.

[2] Anthropic (27 August 2025), *Detecting and countering misuse of AI*. Report.

[3] Anthropic (13 November 2025), *Disrupting the first reported AI-orchestrated cyber espionage campaign*. Report.

[4] Anthropic (3 June 2026), *What we learned mapping a year's worth of AI-enabled cyber threats*. Report.

[5] Anthropic (September 2026), *Detecting and countering misuse of AI: September 2026*. Report.

[6] OpenAI (October 2025), *Disrupting malicious uses of AI*. Report.

[7] Google Threat Intelligence Group (5 November 2025), *Advances in threat actor usage of AI tools*. Report.

[8] Google Threat Intelligence Group (May 2026), *Adversaries leverage AI for vulnerability exploitation, augmented operations, and initial access*. Report.

[9] Google Threat Intelligence Group (8 September 2026), *From prompting to autonomy*. Report.

[10] BleepingComputer (July 2025), CERT-UA's disclosure of LAMEHUG malware using Qwen. Article.

[11] Check Point (2 September 2025), *HexStrike-AI: when LLMs meet zero-day exploitation*. Report.

[12] Palo Alto Networks Unit 42 (30 July 2026), *Chinese-speaking threat actor harnesses AI models for autonomous cyberattacks*. Report.

[13] Gambit Security (22 September 2026), autonomous AI agents compromising online retailers for about US$25 per target. Interim vendor report. Report.

[14] CrowdStrike (7 October 2026), *Unknown threat actor uses AI-driven ARTEX to target South Korean finance*. Moderate-confidence attribution. Report.

[15] Korea Times (14 October 2026), *AI-driven cyberattacks hit 16 financial firms, expose 100,000 records*. Article.

[16] American Banker (October 2026), *AI-linked hacks hit Korean banks through loan-agent sites*. Article.

[17] Straiker (21 October 2026), *Inside CARLIY0S*. Counts targets, not compromises. Report.

[18] CNN (16 May 2024), Arup deepfake loss in Hong Kong. Article.

[19] Sky TG24 (25 September 2026) and Private Banker International (28 September 2026), Fideuram voice-clone fraud. Details from unnamed sources. Sky TG24 · Private Banker International via Yahoo Finance.

[20] Singapore Police Force (7 April 2025), recovery of funds from a deepfake video-call scam with Hong Kong police. Release.

[21] Heiding, F., Schneier, B. et al., *Evaluating large language models' ability to automate spear phishing*. Controlled study, 101 participants. Paper page.

[22] Verizon (19 May 2026), *2026 Data Breach Investigations Report*. Release.

[23] Sullivan & Cromwell (April 2026), Treasury Secretary and Federal Reserve Chair warn bank CEOs about Mythos cyber risks. Memo.

[24] Google Threat Intelligence Group (June 2025, updated), *The cost of a call: from voice phishing to data extortion*. Report.

[25] FBI (26 February 2025), *North Korea responsible for US$1.5 billion Bybit hack*. Public service announcement.

[26] The Record (July 2025), Brazil police arrest IT worker over C&M Software theft. Article.

[27] EVERTEC (September 2025), Form 8-K on the Sinqia incident. Filing.

[28] CISA and partners (27 August 2025), advisory AA25-239A on Chinese state-sponsored network compromise; CISA (December 2024) mobile communications guidance. Advisory · Mobile guidance.

[29] Recorded Future (2 April 2026), *Latin America and the Caribbean cybercrime landscape*. Report.

[30] Check Point (October 2026), *September 2026 cyber threat landscape*. Vendor telemetry. Report.

[31] Al Jazeera (28 October 2025), Venezuela declares Trinidad and Tobago's prime minister persona non grata. Article.

[32] SecurityWeek (January 2026), reports on cyber operations' role in the Maduro capture. Article.

References: AI model capability and policy

[33] UK AI Security Institute (13 April 2026), *Our evaluation of Claude Mythos Preview's cyber capabilities*. Blog.

[34] UK AI Security Institute (17 July 2026), *How far behind the frontier are leading open weight models on cyber?* Blog.

[35] UK AISI and US CAISI (23 July 2026), *Preliminary assessment of Kimi K3's cyber capabilities*. Assessment.

[36] NIST CAISI (17 September 2026), *Assessment of Z.ai's GLM-5.3 cyber capabilities*. Assessment.

[37] NIST CAISI (30 September 2025), *Evaluation of DeepSeek AI models finds shortcomings and risks*. Release.

[38] NIST CAISI (1 May 2026), *Evaluation of DeepSeek V4 Pro*. Release.

[39] Cisco (31 January 2025), *Evaluating security risk in DeepSeek and other frontier reasoning models*. Blog.

[40] Anthropic (29 September 2026), *GLM-5.3 and the spread of advanced cyber capabilities*. Commercial competitor's assessment. Research.

[41] RAND (2026), human uplift study of frontier AI for offensive cyber operations, and follow-up on AI agents. Report.

[42] Flare (20 October 2026), *AI models are fueling a new wave of cybercrime: a quantitative analysis*. Report.

[43] Bank for International Settlements (20 July 2026), *A Mythos moment? Frontier AI and cyber risk*, BIS Bulletin No 129. Bulletin.

[44] BIS Financial Stability Institute (September 2026), *When machines attack: frontier AI cyber threats and policy responses in the financial sector*, Occasional Paper No 28. Paper.

[45] Financial Stability Board (31 August 2026), Chair's letter to G20 Finance Ministers and Central Bank Governors on frontier AI. Letter.

[46] Anthropic (2 June and 6 October 2026), *Expanding Project Glasswing* and *Cyber Verification Program*. Glasswing expansion · Cyber Verification Program.

References: Trinidad and Tobago incidents and fraud

[47] The Record (May 2022), *Trinidad's largest supermarket chain crippled by cyberattack*; TechNewsTT (September 2022) on the Hive group's claim. The Record · TechNewsTT.

[48] The Record (July 2023), *Trinidad and Tobago hit with cyberattack*. Article.

[49] Trinidad Express (February 2024), *Report: hackers accessed TSTT using admin's credentials*; TSTT update (3 November 2023). Express · TSTT.

[50] The Record (December 2023), *Trinidad and Tobago social security agency hit with post-Christmas ransomware attack*. Article.

[51] TechNewsTT (August 2025), *Venture Credit Union announces recovery from ransomware attack*. Article.

[52] Computer Forensics and Security Institute (CFSI), Caribbean ransomware reports for 2024, 2025 and January-June 2026; TechNewsTT on 2023 data. Leak-site listings, anonymised; the author's firm sells security services. 2024 · 2025 · H1 2026 · 2023 · TechNewsTT, April 2026, on breaches beyond listings.

[53] Trinidad Guardian (July 2025), *Online scammers steal millions from CIBC T&T*. Article.

[54] CIBC Caribbean Bank (December 2025), *Annual Report 2025*: Chair's message and cyber disclosures. Annual report.

[55] Trinidad Guardian (March 2026), *Malware attack delays National Quarry financials*. Article.

[56] Trinidad Express (16-17 July 2026), *Businessman questions bank after $1m cyber theft*. Victim's account. Article.

[57] Trinidad Express (26 August 2026), *Fraud Squad gets fewer reports but losses rise 227%*. Article.

[58] FIUTT (March 2026), *Annual Report 2025*; Advisory ADV/003/2025 on onboarding fraud (8 December 2025). Annual report · Advisory.

[59] TTSEC (April 2026) and Ministry of Finance (15 June 2026), public advisories on deepfake videos. TTSEC · Ministry of Finance.

[60] Trinidad Express (November 2025), *$30M scam: inside the collusion between bank staff and car dealers*. Article.

[61] Trinidad Guardian (October 2025), *Rising online fraud worries Central Bank*. Article.

References: Trinidad and Tobago regulation, law and structure

[62] CBTT (September 2025), *Financial Stability Report 2024*. Report.

[63] CBTT (September 2024), *Financial Stability Report 2023*. Report.

[64] CBTT (September 2023), *Cybersecurity Best Practices Guideline for Financial Institutions*, especially Section 3 and Appendix II. Guideline.

[65] CBTT circulars CB-OIFI-399/2025, *Mandatory cybersecurity incident reporting* (5 February 2025), and CB-OIFI-450/2025 on annual self-assessments (11 February 2025). Incident reporting · Self-assessment.

[66] CBTT (August 2022), *Report on the thematic review of commercial banks' cybersecurity risk management practices*. Report.

[67] CBTT (May 2026), *Annual Report 2025*; *Annual Report 2024* (December 2025); risk-based supervision framework effective 1 October 2025. Annual report 2025 · Annual report 2024 · Framework.

[68] CBTT (October 2026), *Strategic Plan 2026/27-2030/31: Insight to Impact*. Plan.

[69] CBTT (28 October 2025), *Central Bank leads collaborative efforts to tackle online banking fraud*. Release.

[70] CBTT, *Licensing procedures for payment system operators* (effective 29 September 2026), *Payment system landscape* and *Payment services* registers; Infolink Services, *About us*; CBTT working paper WP04/2026 on instant payments. Licensing · Landscape · Payment services · Infolink · WP04/2026.

[71] CBTT, *Economic DataPack* (September 2026) and *Monetary Policy Report* (May 2026). DataPack · MPR.

[72] *Financial Institutions Act*, Chap. 79:09, sections 10, 12 and 86. Consolidated text.

[73] Parliament of Trinidad and Tobago, *The Cybercrime Bill, 2017* and bills of the 13th Parliament. Cybercrime Bill · Bills list.

[74] *Data Protection Act*, Chap. 22:04, proclamation status; Senate Hansard (21 April 2026). Legislation library · Hansard.

[75] Senate Hansard (29 October 2025), motion on the growing threat of deepfake technology. Hansard.

[76] Ministry of Finance, *Budget Statement 2026* (13 October 2025) and *Budget Statement 2027* (12 October 2026); *Finance Act 2026*. Budget 2026 · Budget 2027 · Finance Act 2026.

[77] TT-CSIRT, *National cyber security documents*, *Statistics*, and posts and advisories feed. Documents · Statistics · Regional collaboration.

[78] ITU (September 2024), *Global Cybersecurity Index 2024*, country profile. Report.

[79] e-Governance Academy, *National Cyber Security Index: Trinidad and Tobago* (updated April 2025). Index.

[80] TATT (30 January 2026), *Cybersecurity framework for public telecommunications networks*; *Annual market report 2025*. Framework · Market report.

[81] IMF (June 2024), *Trinidad and Tobago: 2024 Article IV Consultation*. Report.

[82] Arthur Lok Jack Global School of Business (January 2025), *Assessing the readiness of Caribbean boards for effective cybersecurity oversight*. Caribbean-wide, all sectors. Study.

[83] Banks' customer security pages and disclosures, viewed October 2026: Republic Bank, Scotiabank Trinidad and Tobago, CIBC Caribbean and ANSA Bank; Republic Financial Holdings *Annual Report 2025*. Republic · Scotiabank · CIBC Caribbean · ANSA Bank · RFHL.

[84] First Citizens Group Financial Holdings (January 2026), *Annual Report 2025*, Appendix 1 skills matrix. Annual report.

[85] Bankers Association of Trinidad and Tobago, *About*. Page.

[86] CIBC Caribbean Bank (28 May 2026), notice of material change on the Butterfield transaction. Notice.

References: international and regional benchmarks

[87] Central Bank of Barbados (revised 31 March 2026), *Technology and cyber risk management guideline*. Guideline.

[88] Bank of Jamaica, *Standard of sound practice on the management of cyber risks* (2024); *Financial Stability Report 2025*; statement on the cyber incident at JETS Limited (23 October 2026). Standard · FSR 2025 · JETS statement.

[89] New York Department of Financial Services: industry letters of 21 May 2026 on frontier AI and on heightened-threat measures; 16 October 2024 letter on AI cyber risks; 23 NYCRR Part 500. Frontier AI · Heightened-threat measures · AI risks 2024 · Part 500.

[90] Bank of England, FCA and HM Treasury (15 May 2026), *Joint statement on frontier AI models and cyber resilience*. Statement.

[91] IMF (April 2024), *Global Financial Stability Report*, Chapter 3, *Cyber risk: a growing concern for macrofinancial stability*. Chapter.

[92] FS-ISAC (October 2024), *Deepfakes in the financial sector: understanding the threats, managing the risks*. Paper.

[93] ICT Pulse (January 2026), summary of the 2025 IDB-OAS cybersecurity maturity report for the Caribbean. Summary.

[94] OSFI (April 2026, modified July 2026), *Technology risk bulletin: frontier artificial intelligence*. Bulletin.

[95] TTSEC (7 July 2023), circular on the enhanced risk-based supervision framework. Circular.

[96] BIS Financial Stability Institute (June 2023), *Banks' cyber security: a second generation of regulatory approaches*, FSI Insights No 50. Paper.

[97] The Record (2024), Patelco Credit Union ransomware and data breach. Article.

[98] Trinidad Express (13 October 2026), *Budget success hinges on execution and policy clarity*, including the Bankers Association's budget response. Article.

[99] Trinidad and Tobago Police Service, *Crime statistics* (2025 data; fraud offences by month). Statistics.

[100] CBTT (23 April 2026), *Understanding cyber threats and financial fraud to stay one step ahead*, public session with BATT and TTSEC. Notice.

[101] CISA and partners (29 July 2025), updated joint advisory on the Scattered Spider group. Alert.

[102] Jamaica Observer (27 October 2026), *Wheatley demands info on MultiLink breach*. Article.

Currency amounts are as published. Conclusions, ratings and scenarios are the report's analysis. They are not statements by the Central Bank of Trinidad and Tobago, TT-CSIRT, any bank or any other institution.